PENETRATION TESTING ASSESSMENT REPORT

Week 4 Pentesting Project — Academic Training Exercise

Target Organization / Scope	medirozahospital.com (IP 199.188.201.16)
Assessment Objective	Access patient portal and extract confidential patient lab reports
Pentester	Mohamed Yusuf
Cybersecurity Mentor	Waqas Karim, CCIE
Organization	Networkwalks
Academic / Training Unit	Batch: B082 | Week 4 Pentesting Project
Document Classification	CONFIDENTIAL
Date of Assessment	October 03, 2026

Assessment Milestones

1. Executive Summary

During the Week 4 Pentesting Project evaluation, a controlled vulnerability assessment was conducted against the target domain medirozahospital.com. The primary objective was to evaluate the security posture of the patient application portal.

The assessment successfully identified a critical vulnerability in the authentication interface, allowing for complete bypass of security controls and unauthorized extraction of protected health information (PHI). An outdated database backup reachable through this bypass exposed three patient report PDF files. File-level password encryption on those documents was audited and found to be highly susceptible to standard dictionary cracking methods.

2. Vulnerability Severity Rankings (CVSS v3.1)

To help the IT department prioritize fixes, the discovered vulnerabilities have been rated using the Common Vulnerability Scoring System (CVSS v3.1 framework):

2.1 SQL Injection on Patient Portal Login

CRITICAL

Impact: This vulnerability allows remote, unauthenticated attackers to completely bypass the login screen, access the backend database, and read, alter, or delete sensitive medical files.

2.2 Exposed Legacy Database Backup

HIGH

Impact: An outdated backup file was left reachable once the login was bypassed, exposing historical patient data that should have been deleted or stored outside the web-accessible path.

2.3 Weak PDF Password Protection

MEDIUM

Impact: The patient report PDFs recovered from the backup relied on weak, common passwords for encryption, which were recovered in seconds using a standard dictionary attack, fully exposing the document contents.

3. Recommendations

- Use parameterized queries / prepared statements on all login and search logic to eliminate SQL injection.
- Remove database backups from web-accessible paths; store them in access-controlled, off-site storage with a retention/deletion policy.
- Enforce strong, non-dictionary passwords and prefer AES-256 over RC4 for any password-protected PDF exports.
- Add logging/alerting for repeated failed logins and unusual query patterns.
- Re-test after fixes are applied to confirm remediation.

4. Conclusion

The assessment found a critical, chained path from an unauthenticated login form to real patient data: SQL injection bypassed authentication, a stale backup exposed patient PDF files, and weak passwords on those files offered no meaningful protection once they were reached. Addressing the SQL injection, securing/removing legacy backups, and enforcing stronger file encryption would close this path and should be treated as a priority for the IT department.